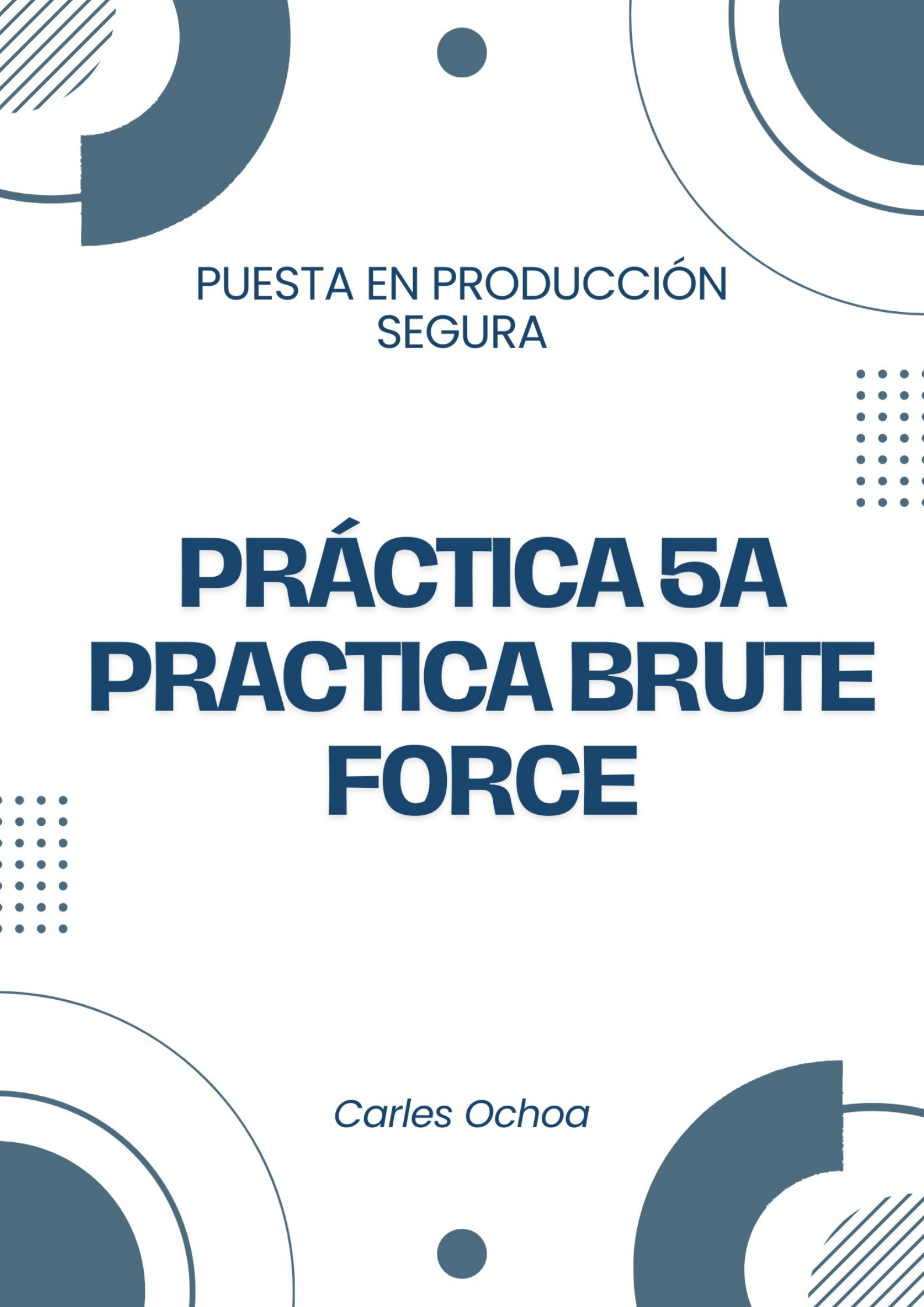




PUESTA EN PRODUCCIÓN
SEGURA

PRÁCTICA 5A

PRACTICA BRUTE

FORCE

Carles Ochoa

Índice

Introducción / Que vamos a realizar.....	3
Preparación de Burp Suite.....	3
Acceder a la vulnerabilidad Brute Force.....	4
Envío de la petición a Intruder.....	4
Configuración de las posiciones en Intruder.....	5
Configuración del payload (diccionario de contraseñas).....	5
Configuración de Grep – Match.....	7
Configuración de Grep – Extract.....	7
Ejecución del ataque de fuerza bruta.....	9

Introducción / Que vamos a realizar

En esta práctica realizaremos un ataque de fuerza bruta sobre un formulario de inicio de sesión de una aplicación web vulnerable. El objetivo es comprobar cómo, mediante el uso de herramientas de seguridad, es posible probar múltiples contraseñas de forma automática hasta encontrar la correcta.

Para ello se utilizará Kali Linux, la aplicación DVWA y la herramienta Burp Suite, empleando un diccionario de contraseñas para automatizar los intentos de acceso. De esta forma se analizarán las respuestas del servidor para identificar cuándo el inicio de sesión es correcto o incorrecto.

Preparación de Burp Suite

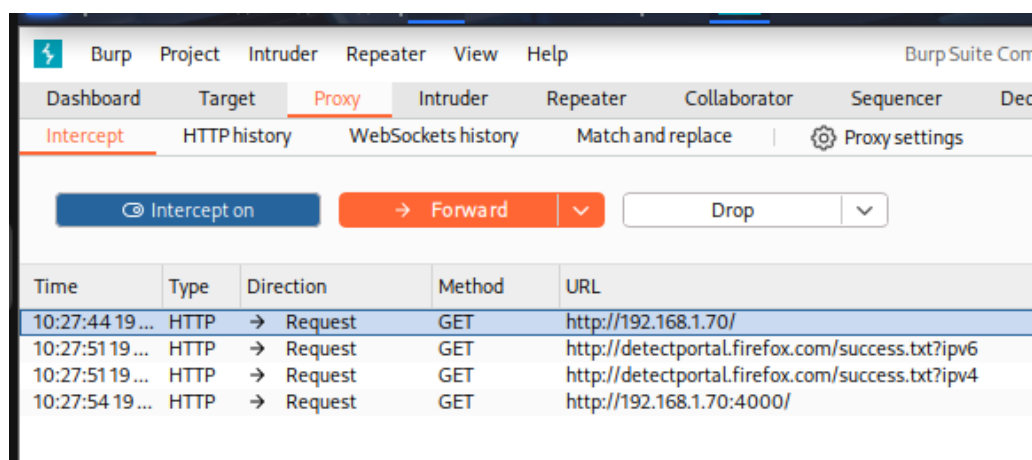
En este paso iniciaremos Burp Suite Community Edition en Kali Linux para que el proxy de Burp este activo y listo para interceptar las peticiones HTTP que se enviarán posteriormente a la aplicación DVWA.

Para ello debemos de introducir en el firefox de kali que el proxy será Burp y para ello los pasos a seguir son:

1. **Menú → Settings / Preferencias**
2. **Baja hasta Network Settings**
3. **Pulsa Settings**
4. **Marca Manual proxy configuration**
5. **Rellena:**
 1. **HTTP Proxy: 127.0.0.1**
 2. **Port: 8080**
6. **Aceptar**

Si todo ha funcionado veremos que en Burp se esta interceptando el tráfico.

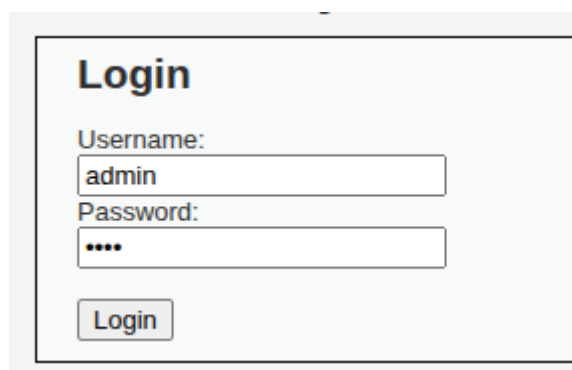
Con esta configuración le hemos dicho al navegador que pase por Burp.



Acceder a la vulnerabilidad Brute Force

En este paso vamos a acceder a la sección vulnerable Brute Force de DVWA con el objetivo de generar una petición de inicio de sesión que posteriormente será utilizada para realizar el ataque de fuerza bruta.

Para ello, desde el menú lateral de la aplicación DVWA, vamos a seleccionar la opción Brute Force. A continuación, vamos a introducir un usuario válido y una contraseña cualquiera en el formulario de inicio de sesión y vamos a enviar la petición, la cual será interceptada por Burp Suite para su posterior análisis.



Time	Type	Direction	Method	URL
12:01:30 19...	HTTP	→ Request	GET	http://192.168.1.70:4000/vulnerabilities/brute/?username=admin&password=test&Login=Login

Envío de la petición a Intruder

Aquí vamos a enviar la petición de inicio de sesión interceptada al módulo Intruder de Burp Suite, con el objetivo de preparar el ataque de fuerza bruta.

Con la petición del login visible en Proxy → Intercept, vamos a hacer clic derecho sobre la petición y seleccionamos la opción “Send to Intruder”.

De esta forma, la petición queda cargada en Intruder y lista para ser configurada, permitiendo automatizar el envío de múltiples contraseñas sobre el mismo usuario.

Time	Type	Direction	Method	URL	Status code	Length
12:01:30 19...	HTTP	→ Request	GET	http://192.168.1.70:4000/vulnerabilities/brute/?username=admin&password=test&Login=Login		

Request	http://192.168.1.70:4000/vul...min&password=test&Login=Login
	Add to scope
	Forward
	Drop
	Add notes
	Highlight >
	Don't intercept requests >
	Do intercept >
	Scan
	Send to Intruder Ctrl+I
	Send to Repeater Ctrl+R

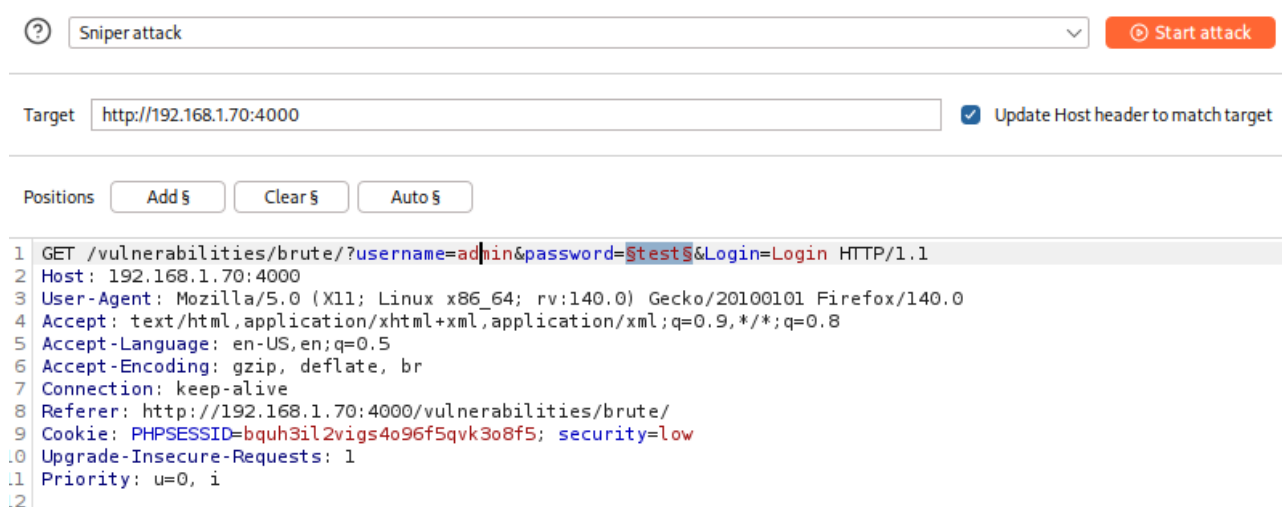
Request
Pretty Raw Hex

Configuración de las posiciones en Intruder

En este paso vamos a configurar qué parámetro de la petición será atacado.

Dentro de Burp Suite, accedemos a la pestaña Intruder. Aquí, vamos a eliminar todos los puntos de entrada automáticos y vamos a dejar marcado únicamente el campo correspondiente a la contraseña (password), ya que el ataque de fuerza bruta se realizará sobre este parámetro.

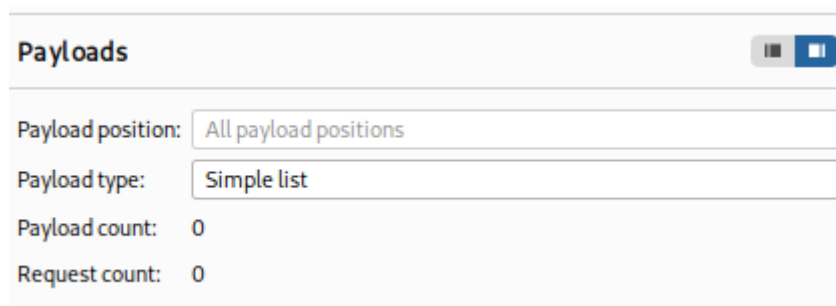
Para eliminar los puntos de entrada pulsamos sobre Clear§ y seguidamente seleccionamos el valor del campo password y pulsamos sobre Add§. Con esto le decimos a Burp que el ataque será solo sobre el password.



Configuración del payload (diccionario de contraseñas)

Vamos a configurar el diccionario de contraseñas que se utilizará para realizar el ataque de fuerza bruta.

Para ello dentro de Intruder, pulsamos sobre la pestaña Payloads. Y en Payload type seleccionamos: Simple list.



El siguiente paso es introducir contraseñas por lo tanto en el cuadro de texto (Payload Options) vamos a pegar diversas contraseñas de una wordlist.

Para ello desde la terminal copiaremos las 20 primeras líneas del fichero derocy.txt

```
(carles@kalicarles)~  
$ cd /usr/share/wordlists  
  
(carles@kalicarles)/usr/share/wordlists  
$ head -n 20 rockyou.txt  
123456  
12345  
123456789  
password  
iloveyou  
princess  
1234567  
rockyou  
12345678  
abc123  
nicole  
daniel  
babygirl  
monkey  
lovely  
jessica  
654321  
michael  
ashley  
qwerty  
  
(carles@kalicarles)/usr/share/wordlists  
$
```

Una vez copiadas pulsamos sobre Paste y ya las tendremos en el Payload.

Payloads

Payload position:

All payload positions

Payload type:

Simple list

Payload count:

20

Request count:

20

Payload configuration

This payload type lets you configure a simple list of strings that are used as payload

Paste

Load...

Remove

Clear

Deduplicate

Add

123456

12345

123456789

password

iloveyou

princess

1234567

rockyou

12345678

abc123

Enter a new item

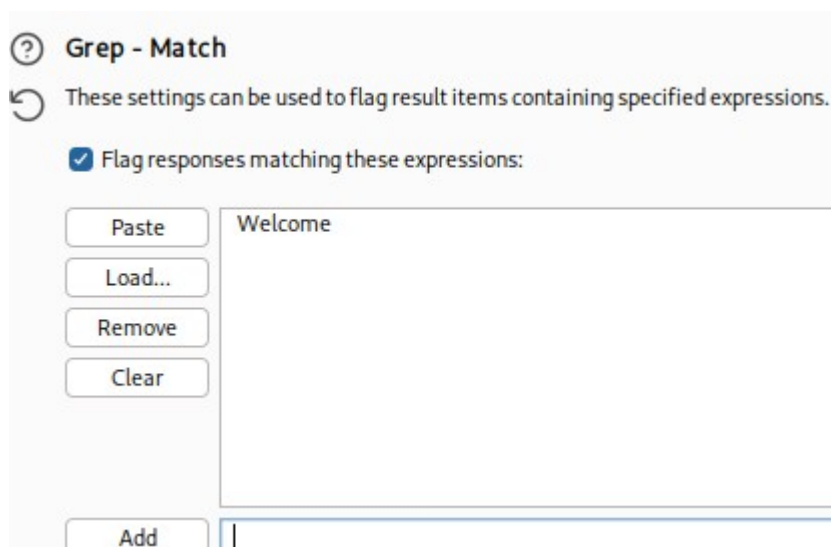
Add from list

[Discussion only]

Configuración de Grep – Match

Vamos a configurar Intruder para identificar cuándo el login es correcto. Para ello:

1. En **Intruder**
2. En el panel derecho, hacemos clic en **Settings**
3. Bajamos hasta encontrar **Grep – Match**
4. Eliminamos todas las coincidencias que aparezcan
5. Añadimos una nueva con el texto: Welcome
6. Tipo: **Simple string**



Configuración de Grep – Extract

En este paso vamos a configurar Intruder para extraer el mensaje de error del servidor, lo que nos permitirá diferenciar claramente entre intentos fallidos y exitosos.

1. En **Intruder**, en el panel derecho, entramos en **Settings**
2. Bajamos hasta encontrar el apartado **Grep – Extract**
3. Pulsamos **Add**
4. En la ventana que se abre pulsamos en **Fetch response** y nos fijaremos en la **respuesta del servidor (Response)** que aparece abajo
5. **Buscamos el texto:** Username and/or password incorrect
6. Lo seleccionamos y pulsamos sobre **OK**.

Define extract grep item

? Define the location of the item to be extracted. Selecting the item in the response panel will create a suitable configuration automatically. You can also modify the configuration manually to ensure it works effectively.

☒ Define start and end

☒ Start after expression:
☐ Start at offset:
☒ End at delimiter:
☐ End at fixed length:

☐ Extract from regex group

☒ Case sensitive

☐ Exclude HTTP headers ☒ Update config based on selection below Refresh response

```

79 Username:<br />
80 <input type="text" name="username"><br />
81 Password:<br />
82 <input type="password" AUTOCOMPLETE="off" name="password"><br />
83 <br />
84 <input type="submit" value="Login" name="Login">
85
86 </form>
87 <pre><br />Username and/or password incorrect.</pre>
88 </div>
89
90 <h2>More Information</h2>
91 <ul>
92 <li><a href="
https://www.owasp.org/index.php/Testing_for_Brute_Force_(OWASP-AT-004)" target="
_blank">https://www.owasp.org/index.php/Testing_for_Brute_Force_(OWASP-AT-004)</a>

```

? ⚙️ ⏪ ⏩ Username and 1 match

OK Cancel

? Grep - Extract

🔄 These settings can be used to extract useful information from responses into the attack results table.

☒ Extract the following items from responses:

Add
Edit
Remove
Duplicate
Up
Down
Clear

From [<pre>
] to [.</pre>]

Maximum capture length:

Ejecución del ataque de fuerza bruta

Con todos los pasos ya realizados, nos faltará ejecutar el ataque. Para ello pulsamos sobre Start Attack.

The screenshot shows the Burp Suite interface within a Kali Linux virtual machine. The main window displays the '8. Intruder attack of http://192.168.1.70:4000'. The 'Results' tab is selected, showing a table of captured requests. The fourth request (index 4) is highlighted, indicating a successful login with the password 'password' and a 'Welcome' message. The 'Request' tab is also visible, showing the raw HTTP request details.

Request	Payload	Status code	Response recei...	Error	Timeout	Length	Welcome	Comment
0		200	4			4703		Username and/or password incorr...
1	123456	200	3			4702		Username and/or password incorr...
2	12345	200	12			4703		Username and/or password incorr...
3	123456789	200	10			4702		Username and/or password incorr...
4	password	200	15			4741	1	
5	iloveyou	200	5			4702		Username and/or password incorr...
6	princess	200	4			4703		Username and/or password incorr...
7	1234567	200	3			4702		Username and/or password incorr...

The 'Request' tab shows the raw HTTP request details, including the GET request to /vulnerabilities/brute/?username=admin&password=password&Login=Login, the Host header, User-Agent, Accept, Accept-Language, Accept-Encoding, Connection, Referer, Cookie, Upgrade-Insecure-Requests, and Priority.

Tras pulsar Start attack, podemos observar en los resultados que la línea 4, cuyo payload es password, muestra un número 1 en la columna Welcome. Esto indica que, durante el ataque, la respuesta del servidor para ese intento contenía la palabra “Welcome” de la wordlist, lo cual coincide con el mensaje que DVWA devuelve cuando las credenciales son válidas.

Por lo tanto, hemos logrado identificar mediante un ataque de fuerza bruta que la contraseña del usuario admin es efectivamente password, confirmando así que el sistema es vulnerable a este tipo de ataques cuando no se implementan medidas de protección adecuadas.